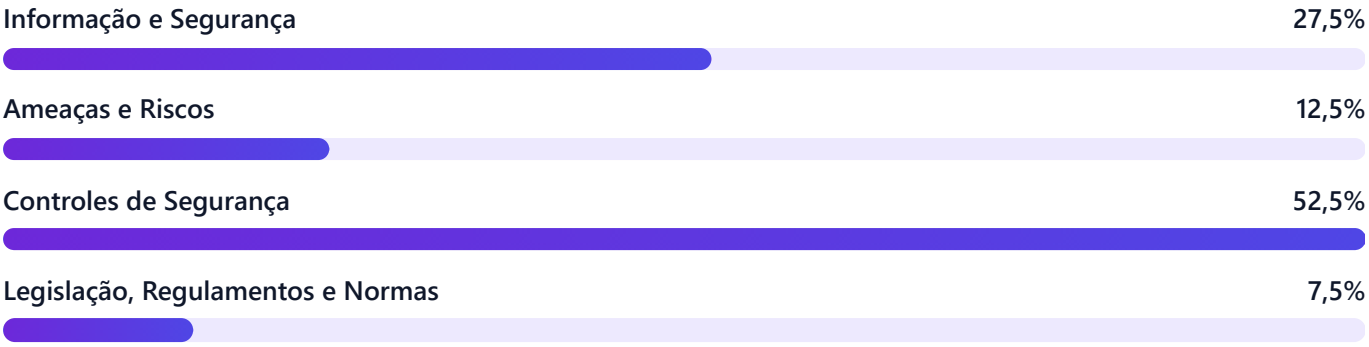
Strecht Simulados

Resumo de bolso
EXIN ISFS ISO 27001

Domínios cobrados, as dicas de prova mais importantes e 10 questões comentadas para treinar.

240	6	65%
questões no curso	provas completas	nota de corte

Como é a prova EXIN ISFS ISO 27001



Material independente de preparação, sem afiliação ou endosso de EXIN. As questões são inéditas e não reproduzem a prova real.

Pronto para o exame EXIN ISFS ISO 27001?

Treine com as 240 questões em 6 provas completas: tempo do exame, explicação de cada alternativa e link da documentação para revisar.

Ver as 6 provas completas e o cupom do mês →

Dicas de prova por domínio

Controles de Segurança

- Sigilo: cifra com a pública do destinatário.
- Backup sem teste: sem garantia.
- Urgência + link + dados: phishing.
- Terceiro com informação sigilosa: NDA.
- Instalação restrita: menos malware e pirataria.
- Desenvolvimento terceirizado: requisitos e verificação.
- Sem crachá: recepção, não carona.
- Sala sensível: discreta.

Informação e Segurança

- Sistema de informação: pessoas + processos + dados + tecnologia.
- Ativo protegido: responsabilidade do proprietário.
- Fóruns de segurança: grupos de interesse.
- Informação tem valor: é ativo.
- Gestão da informação: extrair valor.
- Auditável = registrado e verificável.
- Cadastra e aprova: separar funções.
- SGSI: gestão baseada em risco.

Legislação, Regulamentos e Normas

- 27002: guia dos controles.
- Requisitos: cláusulas 4 a 10.
- Requisitos do SGSI: 27001.
- Certificação: ISO/IEC 27001.
- Dados de cartão: PCI DSS.
- Nuvem: ISO/IEC 27017.
- Privacidade sobre a 27001: ISO/IEC 27701.
- Dados pessoais na UE: GDPR.

Ameaças e Riscos

- Raio: ameaça não humana.

- O que sobra: risco residual aceito.
- ALE = SLE x ARO (0,5).
- Análise de riscos começa pelos ativos.
- Neutro: medidas para não ocorrer ou reduzir dano.
- Ameaça concretizada = incidente.
- Quantitativa: valores para decidir.
- ALE = SLE x ARO.

10 questões para treinar

Responda antes de olhar o gabarito, no fim do material.

Questão 1 · Controles de Segurança

Como deve ser o nível de verificação de antecedentes na contratação de pessoas?

A. Dispensado para cargos com acesso a dados sensíveis
B. Proporcional ao cargo, à informação acessada e aos riscos
C. Feito só depois de um incidente com a pessoa
D. Igual para todos, com investigação máxima em qualquer cargo

Questão 2 · Controles de Segurança

Em quantos temas a ISO/IEC 27002:2022 organiza seus controles?

A. Dois: controles técnicos e controles administrativos
B. Sete, um para cada camada do modelo OSI
C. Quatro: organizacionais, de pessoas, físicos e tecnológicos
D. Catorze domínios de controle, como na edição anterior de 2013

Questão 3 · Controles de Segurança

Após resolver um incidente de segurança, a equipe analisa as causas e atualiza procedimentos. Qual é o objetivo dessa etapa?

A. Aprender com o incidente para evitar que se repita
B. Encontrar um culpado para aplicar uma punição exemplar
C. Apagar os registros para não expor a empresa
D. Encerrar o caso sem nenhuma documentação

Questão 4 · Informação e Segurança

Qual papel é, em geral, responsável por definir a estratégia de segurança da informação da organização como um todo?

A. O usuário final de cada departamento
B. O CISO (Chief Information Security Officer)
C. O fornecedor de antivírus contratado
D. O técnico de suporte do service desk da empresa

Questão 5 · Controles de Segurança

Os resultados trimestrais eram confidenciais até serem divulgados oficialmente ao mercado. O que deve acontecer com a classificação depois da divulgação?

A. Ser apagada, pois informação pública não é ativo
B. Ser revista, pois o valor e o sigilo mudaram
C. Continuar confidencial, pois a classificação nunca muda
D. Ser elevada a secreta, para evitar novos vazamentos

Questão 6 · Informação e Segurança

Um sistema registra o valor "37,8". Na tela do enfermeiro aparece "temperatura do paciente: 37,8 °C". O que mudou?

A. A informação virou um dado bruto sem valor
B. O dado perdeu a integridade ao ser exibido
C. O dado ganhou contexto e virou informação
D. Nada, pois dado e informação são sinônimos

Questão 7 · Controles de Segurança

Após cinco tentativas de senha erradas, a conta do usuário é bloqueada por alguns minutos. Qual ataque esse controle dificulta?

A. Furto de notebooks no aeroporto
B. Inundação da sala de servidores
C. Ataque de força bruta às senhas
D. Falha de energia no centro de dados

Questão 8 · Controles de Segurança

Uma arquitetura usa firewall, segmentação de rede, MFA e criptografia em camadas. Qual princípio de engenharia segura ela aplica?

A. Segurança por obscuridade
B. Ponto único de controle
C. Confiança implícita na rede interna
D. Defesa em profundidade

Questão 9 · Controles de Segurança

Qual tema deve fazer parte do programa de conscientização em segurança da informação?

A. Como compartilhar senhas de forma rápida
B. Como desativar o antivírus para ganhar desempenho
C. Como burlar o bloqueio de sites da empresa
D. Como reconhecer e relatar incidentes, como phishing

Questão 10 · Informação e Segurança

Segundo a ISO/IEC 27001, o que a política de segurança da informação deve incluir?

A. A configuração detalhada de cada firewall da empresa e filiais
B. A lista de senhas dos administradores de cada sistema
C. O nome dos funcionários que já cometeram violações
D. Compromisso com os requisitos e com a melhoria contínua

Gabarito comentado

1. B) Proporcional ao cargo, à informação acessada e aos riscos
Triagem proporcional ao risco.

2. C) Quatro: organizacionais, de pessoas, físicos e tecnológicos
27002:2022: 4 temas, 93 controles.

3. A) Aprender com o incidente para evitar que se repita
Pós-incidente: aprender e melhorar.

4. B) O CISO (Chief Information Security Officer)
Estratégia de segurança: CISO.

5. B) Ser revista, pois o valor e o sigilo mudaram
Valor mudou: revisar a classificação.

6. C) O dado ganhou contexto e virou informação
Dado + contexto = informação.

7. C) Ataque de força bruta às senhas
Bloqueio por tentativas: contra força bruta.

8. D) Defesa em profundidade
Camadas de proteção: defesa em profundidade.

9. D) Como reconhecer e relatar incidentes, como phishing
Conscientização: reconhecer e relatar.

10. D) Compromisso com os requisitos e com a melhoria contínua
Política: compromissos + objetivos.

Pronto para o exame EXIN ISFS ISO 27001?

Treine com as 240 questões em 6 provas completas: tempo do exame, explicação de cada alternativa e link da documentação para revisar.

Ver as 6 provas completas e o cupom do mês →